Zero Trust Quick Reference: Private Sector

Public edition v2.7, 17 October 2026. Public sources only. Ken Connell.

For companies, state and local governments, universities, and anyone else with no federal Zero Trust mandate.

The pattern

QUESTION	USE
What does good look like?	**NIST CSF 2.0** (Feb 2024): six functions: Govern, Identify, Protect, Detect, Respond, Recover
What is Zero Trust?	**NIST SP 800-207** (Aug 2020): the definition, tenets and logical components
Where are we going?	**CISA ZTMM 2.0** (Apr 2023), borrowed as a target: pick a stage per pillar
How did others build it?	**NIST SP 1800-35** (Jun 2025): 19 example implementations, 24 collaborators
How do we segment?	**CISA Microsegmentation Part One** (Jul 2025): written for federal agencies, usable by any organization

If a contract or regulator names a framework, start from that one.

Zero Trust in one breath

No federal Zero Trust mandate binds us, so we chose our own target. We use the Cybersecurity Framework to describe what good looks like, NIST SP 800-207 to define Zero Trust, the CISA maturity model to set a target stage per pillar, and NIST's example builds in SP 1800-35 to see how others got there.

The seven tenets (NIST SP 800-207, in short)

1. Every data source and computing service is a resource.
2. All communication is secured, wherever it comes from.
3. Access is granted per session, per resource.
4. Access is decided by dynamic policy: identity, application or service, device, behavior and environment.
5. Every asset's integrity and security posture is monitored and measured.
6. Authentication and authorization are dynamic and enforced before access.
7. Collect as much as you can about assets, network and communications, and use it to improve.

Where Zero Trust lands in CSF 2.0

- **Govern:** the strategy, the target, who owns it.
- **Identify:** the inventories: users, devices, applications, data, flows.
- **Protect:** identity management, authentication and access control; data security; platform security.
- **Detect:** continuous monitoring that feeds access decisions.
- **Respond and Recover:** containment is easier when access is already segmented and per-request.

Your target (CISA ZTMM 2.0)

Pillar	Traditional	Initial	Advanced	Optimal
Identity				
Devices				
Networks				
Applications and Workloads				
Data				

Mark the stage you are aiming for in each pillar. Write one line of why.

Security idea or Zero Trust idea?

A Zero Trust idea is about a per-request access decision made on identity, device posture and context, enforced and logged, or about the inventory, tag or policy that feeds one.

"The network is segmented" is a security idea. "Data flows are mapped, and critical workloads are segmented on identity, with policy changes applied automatically" is the Zero Trust version (Networks).

Handling CUI for a DoW contract?

Your security requirements come from NIST SP 800-171 and the DoW CMMC program. Zero Trust can help you meet them, but it does not replace them.

Terms

TERM	MEANING
PE / PA / PEP	Policy engine decides, administrator issues, enforcement point allows or blocks each request. PDP = PE + PA.
PIP	Policy information points: identity, device posture, threat intelligence, data tags.
IdP	Identity provider: where users sign in once, and where MFA lives.
Phishing-resistant MFA	MFA a fake login page cannot capture and replay, such as FIDO2 keys.
Microsegmentation	Small, controlled network zones, so a breach cannot easily move laterally.
NCCoE	NIST's National Cybersecurity Center of Excellence, which built the SP 1800-35 examples.
CUI	Controlled unclassified information: sensitive government information contractors must protect.

Sources

NIST SP 800-207, SP 1800-35, CSF 2.0 and SP 800-171 (csrc.nist.gov). CISA ZTMM 2.0 and Microsegmentation Part One (cisa.gov). Full links: kensden.github.io/zero-trust-field-guide/#sources

Copyright 2026 Ken Connell. All rights reserved. Built with Claude.